

Compliance Checklist

Overview

This document reviews Botium Toys' current compliance posture based on the internal security audit. The assessment focuses on identifying whether the organisation follows important compliance best practices related to PCI DSS, GDPR, and SOC security standards.

PCI DSS Compliance

Requirement	Status	Notes
Access to customer credit card information is restricted to authorised users	No	Employees currently have wide access to internal and customer related data
Credit card information is processed and stored securely	No	Payment card information is stored internally without proper protection measures
Data encryption procedures are implemented	No	Customer payment information is not encrypted
Secure password management policies are enforced	No	Password requirements exist but are below modern security standards, and no centralised password management system exists

GDPR Compliance

Requirement	Status	Notes
E.U. customer data is	Partial	Some protections are in

protected and secured		place, but missing controls increase risk to customer data
72-hour breach notification procedure	Yes	The IT department has made procedures for notifying E.U. customers after a breach
Data classification and inventory procedures are implemented	No	Asset management and data classification processes are incomplete
Privacy policies and procedures are enforced	Yes	Privacy related procedures have been developed and communicated to employees

SOC Compliance

Requirement	Status	Notes
User access policies are established	Partial	Access controls exist but least privilege and separation of duties are not implemented
Sensitive information remains confidential	No	Missing encryption and excessive user access increase confidentiality risks
Data integrity controls are implemented	Yes	The IT department has implemented controls to support data integrity
Data is available to authorised users when needed	Partial	Data is available to all users but needs to be limited to individuals who need access to it to do their jobs

Summary

The compliance assessment identified multiple gaps that increase the risk of regulatory violations and exposure of sensitive information. The largest compliance concerns involve weak access control implementation, lack of encryption for payment card data, and insufficient password management practices.

Although Botium Toys has implemented some privacy procedures and operational controls, additional improvements are needed to strengthen compliance with PCI DSS, GDPR, and SOC security standards.